

KILLA COSMETICS

Project Completion & Refactoring Report

Date: May 24, 2026

Developed by: Jules (AI Agent)

Table of Contents

1. Executive Summary
2. List of Changes
3. Security Improvements
4. Architecture Changes
5. Features Added
6. Bugs Found and Fixed
7. Testing Performed and Results
8. Pending Improvements

1. Executive Summary

This report details the comprehensive audit, refactoring, and completion of the Killa Cosmetics web application. The project, originally a procedural PHP application, has been fully transitioned to a robust MVC (Model-View-Controller) architecture. All core functionalities promised in the README have been implemented, secured, and verified. The result is a professional, functional, and production-ready e-commerce management system.

2. List of Changes

Modified Files:

- src/Config/Database.php: Updated to use environment variables for better security.
- src/Core/Controller.php: Added support for layouts, RBAC, CSRF protection, and JSON responses.
- src/Core/Router.php: Implemented a robust routing system with error handling.
- src/Models/Product.php: Added pagination, advanced search, and count methods.
- src/Models/Statistics.php: Fixed queries and table references.
- src/Services/ExportService.php: Fully implemented PDF, Excel, and CSV export logic.
- src/Views/dashboard/inventory.php: Updated to dynamic data and integrated with layout.
- basekilla2.sql: Added missing table 'detalle_ventas'.

New Files:

- public/index.php: Created as the main entry point (Front Controller).
- src/Controllers/AuthController.php: Handled secure login, logout, and session management.
- src/Controllers/DashboardController.php: Managed administrative dashboard logic.
- src/Views/auth/login.php: Login interface with CSRF.
- src/Views/products/list.php: Product listing with search, pagination, and CSRF.
- src/Views/products/form.php: Unified form for CRUD with image upload and CSRF.
- src/Views/layouts/main.php: Master template for consistent UI.
- .env / .env.example: Environment configuration management.
- composer.json: Dependency management.

3. Security Improvements

- Prepared Statements: All database interactions use mysqli prepared statements to eliminate SQL injection risks.
- Password Hashing: Integrated password_hash() for storage and password_verify() for authentication.
- CSRF Protection: Implemented unique token generation and validation for all POST requests, including logout.
- RBAC: Role-Based Access Control limits sensitive operations to authorized users only.
- Input Sanitization: Comprehensive cleaning of user inputs using Validator class.
- Secure Env: Credentials managed via .env, excluding sensitive data from version control.

4. Architecture Changes

- Procedural to MVC: Moved away from scattered .php files to a centralized Controller-Model-View structure.
- Front Controller Pattern: All requests flow through public/index.php, improving security and maintainability.
- PSR-4 Autoloading: Integrated Composer for clean class loading and dependency management.
- Service Layer: Complex business logic like data export isolated in the Services directory.

5. Features Added

- Full CRUD: Complete management of products including image uploads and updates.
- Search & Pagination: High-performance product browsing with server-side pagination.
- Dashboard: Real-time statistics including low stock alerts and top selling products.
- Multi-format Export: Professional exports to PDF, Excel, and CSV.

6. Bugs Found and Fixed

- Missing Table: Added 'detalle_ventas' table to schema.
- Incomplete Model: Implemented missing pagination and count methods in Product model.
- CSRF Vulnerability: Added tokens to all sensitive forms.
- Logout Method: Converted GET logout to secure POST logout.
- Image Handling: Fixed image display escaping and handled image updates in CRUD.

7. Testing Performed and Results

- Auth & CSRF: Verified that forms fail without valid tokens and sessions work correctly.
- CRUD: Tested creation, update, and deletion of products, ensuring data integrity.
- RBAC: Confirmed restricted access for non-admin users across various modules.
- Exports: Validated that generated PDF and Excel files contain the correct product data.

8. Pending Improvements

- Categories Management: Implement a dedicated CRUD for categories.
- Shopping Cart: Add frontend shopping cart functionality for Client role.
- Advanced Analytics: Add interactive charts to the dashboard.